



Cat in Box Manufacturing

Playbook for Cybersecurity Response

July 18/ 2024
Prepared by: Christina McNeice

1. Table of Contents

1. Table of Contents	2
2. Introduction	2
3. Executive Summary	3
3.1. Objective	3
3.2. Summary of Workflow & Playbook	3
3.3. Conclusion	3
4. Client Playbook	3
4.1. Introduction	3
4.2. Roles & Responsibilities	3
4.3. Detection & Analysis	4
4.4. Containment, Eradication & Recovery	4
4.5. Post-Incident	4
5. Incident Response WorkFlow - Phishing Attacks	5
5.1. Detection & Reporting	5
5.2. Initial Assessment	5
5.3. Incident Classification	5
5.4. Incident Notification & Classification	5
5.5. Containment & Remediation	6
5.6. Recovery	6
5.7. Post-Incident Activity	6
6. Communication Template	7
6.1. Technical Letter to MSSP consultant	7
6.2. Non-Technical Letter to CEO	8
7. References	8

2. Introduction

As Cat is in the box manufacturing business they are aware of the changing cybersecurity landscape and have sought the help of Managed Security Service Provider (MSSP). For comprehensive protection of data and operations Cat has tasked MSSP to make a clear handling of the different security issues. Thus the following document presents a plan for responding to incidents and a playbook designed specifically for Cat. Aiming to detail specific handling procedures for a phishing attack scenario. By implementing this plan and playbook, the company will improve detection, response times and reduce impacts, ensuring continued business success. This proactive approach illustrates the company's dedication to security in connection with MSSP.

3. Executive Summary

3.1. Objective

Creating a practical plan for responding to phishing incidents and guiding staff at Cat in box staff with a difficult situation. Helping to handle incidents effectively reducing any negative effects and returning to normal business quickly.

3.2. Summary of Workflow & Playbook

Under the incident response workflow there is a step-by-step procedure for handling phishing attacks. Including identifying attacks, severity level, minimizing problems, recovering from the incident and analyzing the cyberattack after. The client playbook specifies roles, duties type of incident and communication specifics based on attack triggers.

3.3. Conclusion

Implementing this incident response workflow will improve Cat in Box manufacturing's capability of handling such cyberattacks. For full effectiveness it is recommended to regularly review and update this playbook as necessary.

4. Client Playbook

4.1. Introduction

- 4.1.1. The Cat in Box Playbook details the procedures and roles for managing a phishing cyber attack, regardless of confirmation at the time. While adhering to NIST incident response lifecycle and MITRE best practices. ((CISA, Best Practices for Mapping to MITRE ATT&CK, n.d.)

4.2. Roles & Responsibilities

- 4.2.1. SOC Team: Continuous monitoring of network, systems, and data.
- 4.2.2. Cat (MSSP Consultant): Primary coordinator for incident response, oversees security needs.
- 4.2.3. Percy (CEO): Informed of escalated/urgent incidents or unresolved incidents after 48 hours.
- 4.2.4. Misha (Production Manager): Notified of major highlights and potential impacts (Weekdays 9AM-5PM AST).
- 4.2.5. Minka (Alternate Manager): Covers for Misha after hours and on weekends.
- 4.2.6. Dusty (Database Specialist): Handles incidents involving databases.
- 4.2.7. Lucky (IT Support Specialist): Handles incidents involving IT infrastructure.
- 4.2.8. Ned (Network Administrator): Handles incidents involving the network.

4.3. Detection & Analysis

- 4.3.1. Detection :
 - SOC Team notes potential incident or receives end-point reporting of potential incident
- 4.3.2. Initial Analysis :
 - Incident is confirmed by SOC Team via an initial assessment of severity and preliminary information
 - The SOC Team will inform Cat immediately

4.4. Containment, Eradication & Recovery

- 4.4.1. Classification & Notification
 - Cat classify incident, reviews it
 - Major incidents reported to production managers
 - Serious incident or remains unsolved after 24 hours - escalate to company's CEO
- 4.4.2. Assemble Response Team
 - Cat notifies relevant personal of company depending on incident type
- 4.4.3. Containment & Recovery

- Response Team cooperates effectively to contain and remediate incident
- Continuous communication to SOC Team and production managers

4.5. Post-Incident

- 4.5.1. MSSP send a detailed incident report to SOC Team
- 4.5.2. MSSP send incident report and exec summary to CEO
- 4.5.3. MSSP complete full review of incident with actionable items and root-cause
- 4.5.4. MSSP to update playbook based on full review

5. Incident Response WorkFlow - Phishing Attacks

Workflow and playbook based on guidelines provided by the following;

- SANS Incident Handler's Handbook (SANS, 2012)
- Incident Detection, Response, and Prevention (CISA, n.d.)
- Federal Government Cybersecurity Incident & Vulnerability Response Playbooks Operational Procedures for Planning and Conducting Cybersecurity Incident and Vulnerability Response Activities in FCEB Information Systems. (CISA, 2021)
- National Institute of Standards and Technology (NIST) Special Publication 800-61 Revision 2: Computer Security Incident Handling Guide. (NIST 800-61, n.d.)

5.1. Detection & Reporting

- 5.1.1. Action
 - Cat in Box staff or SOC informs MSSP of incident
- 5.1.2. Supporting Questions
 - How was the incident detected? Who brought it to our attention?
 - What was noticeable about the incident that made it detectable?

5.2. Initial Assessment

- 5.2.1. Action
 - The SOC Team continues to assess the incident's scope and validity. While beginning to gather supporting evidence (logs, files, emails etc.
- 5.2.2. Communication
 - SOC team will notify the MSSP with initial findings

- SOC team will continue with incident report

5.2.3. Supporting Questions

- How was the phishing received? (email,etc)
- What is the worst case at this time?
- Is there any proof of compromise?

5.3. Incident Classification

5.3.1. Action

- MSSP will review initial findings and classify the incident. Classification will depend on the incident's severity, type and potential company impact.

5.4. Incident Notification & Classification

5.4.1. Action

- MSSP provides notification to company personnel based on classification
 - Major Impact (Production Managers - both)
 - Unresolved issues after 24 hrs - company CEO.
 - Escalated issues - company CEO.
- MSSP activates Response Team as needed
 - Database issues
 - Network Support
- IT Infrastructure Specialist

5.5. Containment & Remediation

5.5.1. Action

- MSSP and specialists will cooperate to rectify the incident

5.5.2. Communication

- Continuous incident updates will be provide to the SOC Team and Product manager
- Reassessment of incident significance. Should the incident become severe or be unsolved for more then 24 hours, MSSP is to update the company's CEO

5.5.3. Supporting Question

- To contain this, what privileges should be altered? Has the credentials been reset? Are there any other access points the attacker has access to?
- Is the incident worsening? Has it been more than 24 hours since detection?

5.6. Recovery

5.6.1. Action

- Recovery team will restore system to normal operations and monitor for signs of continued compromise

5.6.2. Communication

- Provide recovery status with incident report to date to SOC

5.6.3. Supporting Question

- Which systems are affected? Are there acceptable backups for compromised data?
- What signs of compromise are being continually monitored for?

5.7. Post-Incident Activity

5.7.1. Action

- MSSP complies fill incident report
- MSSP runs an incident analysis to determine root cause and reviews the incident for playbook improvements

5.7.2. Communication

- Comprehensive details, close report for SOC team
- Prepare exec summary for CEO

5.7.3. Supporting Question

- Was there any steps we could have taken to improve response efforts? Were communications smooth and effective? What allowed/ began this incident? Can it be limited to decrease chance of recurrence?
-

6. Communication Template

6.1. Technical Letter to MSSP consultant

Subject: Incident Report - Cat in Box Manufacturing
Priority: HIGH

To: Cat (MSSP consultant)

Send to: cat@soc.cat

From: [Your Email]

Date: [Current Date]

Dear Cat,

We have identified a phishing attack targeting Cat in Box Manufacturing. The victim, an employee, provided their credentials in the attack, compromising internal systems.

Incident Details:

- Time of Detection: [Date and Time]
- Compromised Accounts: [Compromised Accounts]
- Affected Systems: [Affected Systems]

Actions Taken:

- SOC Team has done an initial assessment of the incident
- Access has been revoked by resetting passwords
- Removal of phishing email from all inboxes
- Scanning systems for additional cybersecurity threats

Next Steps:

- Monitoring of systems for residual compromise.
- Complete post-incident review and report
- Determine necessity of notifying stakeholders

Best regards,

[Your name]

SOC Team

6.2. Non-Technical Letter to CEO

Subject: Phishing Attack Cybersecurity Update

To: Mr.Percy F., CEO, Box Manufacturing
Send to: percy@box.cat
From: [Your Email]
Date: [Current Date]

Dear Mr. Percy F.,

I wanted to inform you of a recent phishing incident at Cat in Box Manufacturing. The phishing attack revealed an employee's credentials and has led to a temporary compromise of the company's computer system.

Main details

- Date of Incident: [Date]
- Impact: the affected systems are isolated and credentials reset
- Current status: Under control with systems being monitored

Our team has taken immediate actions to minimize the threat and are working closely with Cat in Box teams to remediate the situation as quickly as possible

Best regards,
Cat,
MSSP

7. References

CISA. (n.d.). *Best Practices for Mapping to MITRE ATT&CK*. CISA. Retrieved July 12, 2024, from <https://www.cisa.gov/sites/default/files/2023-01/Best%20Practices%20for%20MITRE%20ATTCK%20Mapping.pdf>

CISA. (n.d.). *Incident Detection, Response, and Prevention | Cybersecurity and Infrastructure Security Agency CISA*. CISA. Retrieved July 16, 2024, from <https://www.cisa.gov/topics/cyber-threats-and-advisories/incident-detection-response-and-prevention>

CISA. (2021). *Federal Government Cybersecurity Incident & Vulnerability Response Playbooks Operational Procedures for Planning and Conducting Cybersecurity Incident and Vulnerability Response Activities in FCEB Information Systems*. https://www.cisa.gov/sites/default/files/2024-03/Federal_Government_Cybersecurity_Incident_and_Vulnerability_Response_Playbooks_508C.pdf

NIST 800-61. (n.d.). *Computer Security Incident Handling Guide*. NIST Technical Series Publications. Retrieved July 12, 2024, from <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-61r2.pdf>

SANS. (2012, February 21). *Incident Handler's Handbook*. SANS Institute. Retrieved July 16, 2024, from <https://www.sans.org/white-papers/33901/>